

감사결과 처분요구서

분류번호	2024-119	요구일자	2024.12.26.	처분종류	부서주의
처분대상부서	△△△△팀	조치부서	△△△△팀	회신기일	2025.02.26.
건 명	정보화 업무 종합감사 - 시스템 접근제어 권한 관리 부적정 -				

1. 업무개요

△△△△팀은 필요시 내·외부 시스템, 방화벽, DB 등에 대한 접근권한을 부여하고 있으며 이를 위해 권한 부여 및 삭제 신청서를 접수하여 승인하고 있다.

2. 관계법령 및 판단기준

「행정기관 정보시스템 접근권한 관리 규정」 제13조(접근권한 부여 기준)에 따르면 권한관리책임자는 법령 또는 업무규정 등을 근거로 중요도에 따른 접근권한 부여 범위의 차등화 등을 고려하여 업무담당자의 접근권한 부여 기준을 마련하여야 한다.

또한, 동 규정 제15조(접근권한 심사)에 따르면 권한관리책임자는 제13조에 따른 접근권한 부여의 기준에 따라 다음 각 호의 사항을 심사하여 최소한의 접근권한을 부여하여야 하며, 국가 안보와 관련된 정보시스템 등 주요 정보시스템에 대한 접근권한은 기관별로 접근권한 심사위원회를 구성하여 접근권한을 심사할 수 있다.

[행정기관 정보시스템 접근권한 관리 규정]

제13조(접근권한 부여 기준) ① 권한관리책임자는 법령 또는 업무규정 등을 근거로 다음 각 호의 사항을 참조하여 업무담당자의 접근권한 부여 기준을 마련하여야 한다.

- 정보시스템의 종류 및 중요도에 따른 접근권한 부여 범위의 차등화
- 국민의 개인 신상, 재산, 인가 등과 관련된 정보의 접근권한은 업무와 관련 있는 담당자 및 결재권자로 제한
- 내부 의사결정과 관련된 행정정보는 정보의 중요도에 따라서 접근권한 부여 범위를 업무담당자 및 결재권자, 업무관련 부서 또는 기관 단위로 제한
- 행정기관의 행정통계와 관련된 정보의 접근권한은 관련 부서 또는 기관 단위로 제한
- 공개되어도 상관없는 정보의 접근권한은 기관 단위로 제한하거나 허용

제15조(접근권한 심사) ① 권한관리책임자는 제13조에 따른 접근권한 부여의 기준에 따라 다음 각 호의 사항을 심사하여 최소한의 접근권한을 부여하여야 하며, 국가 안보와 관련된 정보시스템 등 주요 정보시스템에 대한 접근권한은 기관별로 접근권한 심사위원회를 구성하여 접근권한을 심사할 수 있다.

1. 정보시스템 또는 행정정보의 이용 또는 활용목적의 정당성
2. 정보시스템 또는 행정정보 이용 범위의 적정성
3. 신청내용의 타당성, 적합성, 공익성

「정보화업무처리 및 정보보안관리지침」 제21조의2(개별사용자 보안)에 따르면 정보보안담당관은 소관 정보통신망 또는 정보시스템의 사용과 관련하여 개별사용자 보안에 관련된 절차 및 방법을 마련하여야 한다.

또한, 동 지침 제22조(계정관리)에 따르면 시스템관리자는 개별사용자의 보직변경, 퇴직, 계약종료 등 변동사항이 발생할 경우에는 신속히 사용자 계정을 삭제하거나 부여된 접근 권한을 회수하여야 한다.

[정보화업무처리 및 정보보안관리지침]

제21조의2(개별사용자 보안) ① 정보보안담당관은 소관 정보통신망 또는 정보시스템의 사용과 관련하여 다음 각 호의 사항을 포함한 개별사용자 보안에 관련된 절차 및 방법을 마련하여야 한다.

1. 직위·임무별 정보통신망 접근권한 부여 심사
2. 보안서약서 징구 등 보안조치
3. 보직변경, 퇴직 등 변동사항 발생시 정보시스템 접근권한 조정

제22조(계정관리) ⑦ 시스템관리자는 개별사용자의 보직변경, 퇴직, 계약종료 등 변동사항이 발생할 경우에는 신속히 사용자 계정을 삭제하거나 부여된 접근 권한을 회수하여야 한다.

⑧ 시스템관리자는 사용자 계정 부여 및 관리의 적절성을 연 2회 이상 점검하고 그 결과를 정보보안담당관에게 보고하여야 한다.

⑨ 시스템관리자는 제1항 및 제7항에 의한 접근권한 부여, 변경, 회수 또는 삭제 등에 대한 내역을 기록하고 3년 이상 보관하여야 한다.

3. 감사결과 확인된 문제

△△△△팀이 관리하고 있는 20xx-20xx년 시스템 접근제어 관리대장을 확인한 결과,

△△△△팀은 신청내용에 따라 영구, 임시로 구분하여 권한을 부여하고 있었으나 영구, 임시 권한부여에 대한 적정성 검토 없이 권한이 부여되고 있었다. 정보화업무 수행을 위한 상주 용역사 직원이더라도 적정기간 동안 권한을 부여받고 권한 부여의 적정성에 대해 주기적 모니터링을 할 필요가 있으나 권한 부여 적정성에 대한 모니터링 없이 영구적으로 권한을 부여하고 있었다. △△△△팀은 「행정기관 정보시스템 접근권한 관리 규정」에 따라 접근권한 부여 기준을 마련하고 적절한 심사를 통해 권한 부여가 이루어져야 하나 이러한 기준 및 심사 과정 없이 신청서에 작성된 대로 권한이 부여되었다.

[시스템 접근제어 신청서 발급 현황 중 일부 발췌]

신청일시	소속	신청사유	부여권한	비고

또한, 시스템 접근제어 신청서를 접수하고 있으나 대장으로 관리되지는 않아 부여된 권한에 대한 전체적인 현황 모니터링은 되지 않고 있었고 시스템 접근제어 신청 후 삭제가 필요할 경우 삭제 신청서를 제출하도록 하고 있지만 삭제를 신청한 건수가 권한 신청서에 비해 현저히 적은 것으로 보아 적절한 조치가 이루어지지 않고 있는 것으로 판단된다.

[시스템 접근제어 권한 부여 및 삭제 신청서 접수 현황]

연도	권한 부여 신청서	권한 삭제 신청서	비고

또한, 「정보화업무처리 및 정보보안관리지침」에 따르면 보직변경, 퇴직, 계약종료 등 변동사항이 발생할 경우에는 신속히 사용자 계정을 삭제하거나 부여된 접근권한을 회수하도록 되어 있으나 20xx.x.xx.기준으로 내부망 하이웨어 접근권한 보유자를 확인한 결과, 부서 이동자, 휴직자의 접근권한이 삭제되지 않고 그대로 권한이 유지되고 있었다. 그리고 내부망 하이웨어 접근권한 보유자와 접근권한 신청서를 비교한 결과, 접근권한 부여 신청서 없이 권한을 부여받은 경우도 확인되었다.

[내부망 하이웨어 접근 권한 보유 현황 확인(20xx.x.xx. 기준)]

소속	권한 보유자	보유 권한	확인결과

관련부서 의견 및 검토결과

이에 대해 △△△△팀은 분기별 보안정책 점검을 통해 서버팜, DMZ, 용역망 등 방화벽, 시스템 접근제어(내외부), DB접근(내외부) 등에 대한 접근 권한을 관리하고 있으며 접근이 허가된 계정이 한달간 미사용 상태일 경우 사용권한이 정지되고 xxx일간 미사용 상태일 경우 분기별 점검시 일괄 삭제하고 있다고 설명하였다.

△△△△팀에서 실시하고 있는 분기별 정보보호시스템 보안정책 점검 결과를 아래와 같이 확인한 결과, 20xx.x월에 xxx건이 한꺼번에 삭제되는 등 분기별로 삭제건수가 들쭉날쭉하고 20xx-20xx년에는 신규 신청건수가 없는 분기도 있는 등 점검결과를 신뢰하기 어렵다. 구체적으로 시스템접근 제어 신청서와 분기별 정보보호시스템 보안정책 점검 결과를 비교하여 확인한 결과, 20xx년 x분기의 경우 시스템접근 제어 신청서로 확인한 신규 건수는 xx건이고 삭제 건수는 x건이나 보안점검 결과는 신규 xx건, 삭제 x건으로 불일치하였다. 또한 20xx년의 경우, 시스템접근 제어 신청서로 확인한 신규 건

수는 xx건이나 보안정책 점검 결과로 확인된 신규 건수는 x건이었다.

[정보보호시스템 보안정책 점검 결과]

연도	시기	점검대상 장비	변경사항 총합	신규	변경	삭제	확인결과

또한, 보안정책 점검의 경우, 용역사 직원이 점검을 실시하며 일괄적으로 삭제처리 후 △△△△팀에 보고하면 그 결과를 첨부하여 내부결재를 올리고 있어 삭제에 대한 △△△△팀의 검토 없이 업무가 진행되고 있는 것으로 확인되었다.

4. 조치할 사항

△△△△팀은, △△△△팀에서 부여하는 각종 권한이 적절성에 대한 심사 과정 없이 무분별하게 부여되지 않도록 업무담당자의 접근 권한 부여 기준을 마련하고 부여된 권한의 적절성이 실효적으로 점검될 수 있도록 업무에 유의하시기 바랍니다.

(부서주의)

감사종류	종합감사
------	------